

HIPAA SECURITY RISK ANALYSIS

SunRidge Health Partners

Ocala, Florida | Integrated Health Network

Effective Date: June 2025

Methodology: 45 CFR 164.308(a)(1) | NIST SP 800-30 Rev. 1 | HHS SRA Guidance

Prepared by: GRC & Compliance Department

Classification: CONFIDENTIAL — FOR INTERNAL USE ONLY

EXECUTIVE SUMMARY

SunRidge Health Partners, an integrated health network serving approximately 85,000 patients across Marion, Sumter, Lake, and Citrus Counties in Central Florida, commissioned this HIPAA Security Risk Analysis (SRA) in response to a significant disruption to its revenue cycle operations during the February 2024 national clearinghouse ransomware event — and in anticipation of the most substantial update to the HIPAA Security Rule in over a decade.

This SRA was conducted in accordance with 45 CFR 164.308(a)(1)(ii)(A) and guided by NIST Special Publication 800-30, Revision 1 (Guide for Conducting Risk Assessments). The analysis encompasses all electronic protected health information (ePHI) created, received, maintained, or transmitted across SunRidge's five primary information systems, four care facilities, and fourteen Business Associate relationships.

CRITICAL FINDING: During SRA preparation, unauthorized web tracking technologies (Google Analytics and Meta Pixel) were discovered actively embedded on patient appointment scheduling pages — constituting an ongoing, unmitigated HIPAA Privacy Rule violation per HHS OCR's December 2022 bulletin on web tracking. Immediate remediation is required.

The assessment identified ten (10) distinct risk scenarios. Three risks were rated CRITICAL (Score 20–25), four risks were rated HIGH (Score 15–19), and three risks were rated MEDIUM (Score 8–14). No LOW risks were identified, reflecting the organization's current security posture and the elevated threat environment facing the healthcare sector.

Key Findings at a Glance

Total Risks Identified	10 risk scenarios across 7 ePHI systems and 14 Business Associates
CRITICAL Risks (Score 20–25)	3 — Ransomware (25), Clearinghouse BA Compromise (20), Tracking Pixel Disclosure (15*)
HIGH Risks (Score 15–19)	4 — Legacy Lab System (16), BA Security Gaps (16), Credential Stuffing (12), Telehealth (12)
MEDIUM Risks (Score 8–14)	3 — Unencrypted Devices (12), Insider Threat (12), Physical Security (9)
Active Violations	1 — Web tracking pixel PHI disclosure (R-09) — IMMEDIATE action required
Primary Threat Vector	Ransomware via spear-phishing (mirrors Ascension Health, May 2024 attack)
Critical Dependency Risk	Single clearinghouse BA with no backup or current BAA (mirrors Change Healthcare, Feb 2024)
Total Remediation Investment	~\$303,500 over 365 days
OCR Penalty Exposure (If Unaddressed)	Up to \$1.9M per violation category per year
Next SRA Due Date	June 2026 (Annual requirement per 164.308(a)(8) and proposed NPRM)

ORGANIZATION PROFILE

SunRidge Health Partners is a covered entity under HIPAA, operating as an integrated health network providing acute care, outpatient services, and behavioral health across Central Florida's retirement corridor.

Organization Name	SunRidge Health Partners, Inc.
Entity Type	Covered Entity — Integrated Health Network (Healthcare Provider)
Headquarters	1847 SW College Road, Ocala, Florida 34471
Service Area	Marion, Sumter, Lake, and Citrus Counties — Central Florida
Patient Population	~85,000 active patients 68% Medicare / Medicare Advantage
Workforce	~1,400 employees and contractors
Facilities (4)	Ocala Regional Medical Center (287-bed acute care) The Villages Health & Wellness Clinic Leesburg Outpatient Center Crystal River Behavioral Health Center
Primary EHR	Epic Systems (cloud-hosted, all facilities)
Supporting Systems	LabCore HL7 v2 (legacy, EOL) MedBridge Revenue Cycle / Clearinghouse MyChart Patient Portal Teladoc Telehealth (2022) Meditech Legacy ERP (read-only)
Business Associates	14 active BAs with varying ePHI access rights

CONTEXT: SunRidge serves a predominantly elderly Medicare patient population in Central Florida's retirement corridor — including the Villages metropolitan area (pop. 130,000+, median age 72). This demographic is a documented priority target for healthcare threat actors due to high-value Medicare billing data and patients with extensive medical histories.

SCOPE AND METHODOLOGY

Regulatory Authority

This SRA is mandated by 45 CFR 164.308(a)(1)(ii)(A), which requires covered entities to conduct an accurate and thorough assessment of the potential risks and vulnerabilities to the confidentiality, integrity, and availability of ePHI held by the organization. The SRA must be performed prior to implementation of security measures and whenever environmental or operational changes occur that may affect ePHI.

Methodology

This assessment was conducted using the NIST Special Publication 800-30, Revision 1 (Guide for Conducting Risk Assessments) framework, adapted to healthcare under the HHS SRA Tool guidance (2014). The methodology involves:

- ◆ Identify and characterize all information systems that store, process, or transmit ePHI (Threat Identification)
- ◆ Identify potential threats and vulnerabilities specific to each system and the organization (Threat Characterization)
- ◆ Assess the likelihood of threat exploitation given current controls (Likelihood Determination)
- ◆ Assess the potential impact of successful threat exploitation on ePHI confidentiality, integrity, and availability (Impact Determination)
- ◆ Determine risk level as Likelihood × Impact on a 1–5 scale (Risk Determination)
- ◆ Identify and prioritize risk response options including remediation, transfer, acceptance, or avoidance (Risk Response)

Risk Scoring Scale

CRITICAL (Score 20–25)	Immediate remediation required. Significant risk to patient safety, regulatory standing, or PHI for large patient populations.
HIGH (Score 15–19)	Remediation within 90 days. Substantial PHI exposure or operational disruption risk.
MEDIUM (Score 8–14)	Remediation within 180 days. Manageable with compensating controls and scheduled remediation.
LOW (Score 1–7)	Accept with compensating controls. Monitor annually through standard review cycle.

Regulatory Context: HIPAA Security Rule NPRM (December 2024)

On December 27, 2024, HHS OCR published a Notice of Proposed Rulemaking (NPRM) proposing the first substantive update to the HIPAA Security Rule since 2013. The NPRM was driven by a 102% increase in large healthcare breaches from 2018–2023 and a 1,002% increase in individuals affected. Key proposed changes that directly impact SunRidge's current risk posture include:

- ◆ Mandatory multi-factor authentication (MFA) for all systems accessing ePHI — no addressable/required distinction
- ◆ Mandatory encryption of ePHI at rest and in transit — SunRidge currently has gaps on both requirements
- ◆ Network segmentation between clinical and administrative systems
- ◆ Vulnerability scanning at minimum every six months; penetration testing annually
- ◆ Annual compliance audit of all HIPAA Security Rule standards
- ◆ Updated Business Associate requirements including minimum cybersecurity standards

The NPRM Final Rule is anticipated in 2026. This SRA identifies all areas where SunRidge's current posture is non-compliant with proposed requirements, enabling proactive remediation ahead of enforcement.

HEALTHCARE THREAT LANDSCAPE — 2024-2025

The healthcare sector has experienced an unprecedented escalation in cybersecurity threats over the 24 months preceding this SRA. SunRidge's geographic profile, patient demographics, and technology infrastructure place the organization in a high-risk exposure category across multiple threat vectors.

Industry-Wide Threat Statistics

- ◆ 458 confirmed ransomware attacks against U.S. healthcare organizations in 2024 — healthcare represents 17% of all ransomware incidents across industries
- ◆ 2025 is the worst year on record for healthcare data breaches: 772 large breaches affecting 139.7 million individuals as of mid-year (HHS OCR Breach Portal)
- ◆ Average healthcare ransomware recovery time: 18 days; average cost: \$10.9 million per incident (IBM Cost of a Data Breach Report 2024)
- ◆ Business Associate breaches now account for 40%+ of healthcare data breach volume — a single compromised BA can expose an entire covered entity's patient population

Key Events Informing This SRA

Change Healthcare Ransomware Attack (February 2024)

The ransomware attack on Change Healthcare — a UnitedHealth Group subsidiary operating as a billing clearinghouse Business Associate — represents the largest healthcare data breach in U.S. history. Approximately 192.7 million individuals had their protected health information exposed, including diagnoses, insurance details, Social Security numbers, and treatment records. The attack disrupted claims processing for over 40,000 healthcare providers nationwide, with many unable to submit claims for 4–6 weeks.

DIRECT RELEVANCE TO SUNRIDGE: SunRidge's revenue cycle operations were disrupted for 11 days during this event due to reliance on a single billing clearinghouse Business Associate. The organization had no alternate clearinghouse arrangement, no tested business continuity plan for billing disruption, and a BAA that had not been reviewed since 2021. This event is the primary trigger for this SRA.

Ascension Health Ransomware Attack (May 2024)

Ascension Health, one of the largest non-profit health systems in the United States operating 140 hospitals across 19 states, suffered a ransomware attack that forced clinical staff to abandon EHR access and revert to paper-based records for several weeks. The attack disrupted access to Epic across all facilities, impacted surgical scheduling, laboratory operations, and pharmacy systems, and affected 5.6 million patients.

DIRECT RELEVANCE TO SUNRIDGE: The Ascension attack was initiated through a phishing email targeting a single employee — the same threat vector identified as Risk R-01 (Score: 25 — CRITICAL). SunRidge's current email security posture (no DMARC/DKIM enforcement, no phishing simulation program, annual-only security training) mirrors the conditions that enabled this attack.

Florida Department of Health RansomHub Breach (June 2024)

The Florida Department of Health suffered a cyberattack claimed by the RansomHub ransomware group, resulting in the unauthorized access and exfiltration of 100 gigabytes of data affecting 729,699 Florida residents. The data was published

publicly when the ransom was not paid. This incident heightened regulatory awareness across Florida's healthcare sector, with Florida AHCA subsequently proposing new breach reporting and continuity planning requirements.

Kaiser Permanente Web Tracking Pixel Disclosure (2024)

Kaiser Permanente disclosed that web tracking technologies — including pixels from Google and Microsoft — embedded on its patient portal had been transmitting protected health information to third-party advertising platforms. The disclosure affected 13.4 million patients and prompted multiple OCR investigations. The information transmitted included medication names, medical condition searches, appointment dates, and provider information.

DIRECT RELEVANCE TO SUNRIDGE: During preparation for this SRA, SunRidge's compliance team discovered that Google Analytics and Meta Pixel tracking codes are currently active on patient-facing appointment scheduling pages. This is an active, ongoing HIPAA Privacy Rule violation per HHS OCR's December 2022 bulletin. Immediate removal and breach notification assessment are required. See Risk R-09.

RISK ASSESSMENT FINDINGS

The following table summarizes all ten (10) risk scenarios identified during this assessment. Risk scores are calculated as Likelihood × Impact on a 1–5 scale. Complete risk details — including full threat descriptions, vulnerability analysis, current controls, NPRM gap analysis, and recommended controls — are documented in the accompanying Excel workbook (Tab: Risk Register).

ID	Risk Title	L	I	Score	Level	CFR Reference
R-01	Ransomware via Spear-Phishing	5	5	25	CRITICAL	164.308(a)(1); 164.308(a)(5)
R-02	Third-Party Clearinghouse BA Compromise	4	5	20	CRITICAL	164.308(b)(1); 164.314(a)
R-03	Unencrypted ePHI on Mobile Devices	4	3	12	MEDIUM	164.310(d)(1); 164.312(a)(2)(iv)
R-04	Privileged Access Abuse / Insider Threat	3	4	12	MEDIUM	164.308(a)(3); 164.308(a)(4)
R-05	Legacy Lab Interface System (EOL Software)	4	4	16	HIGH	164.308(a)(1); 164.312(a)(1)
R-06	Patient Portal Credential Stuffing	4	3	12	MEDIUM	164.312(a)(1); 164.312(d)
R-07	Telehealth Platform Misconfiguration	3	4	12	MEDIUM	164.308(a)(1); 164.312(e)(1)
R-08	Business Associate Security Gaps (TPRM)	4	4	16	HIGH	164.308(b); 164.314(a)
R-09	Web Tracking Pixel PHI Disclosure	5	3	15	HIGH	164.502(a); 164.514(b)
R-10	Physical Security / Unattended Workstations	3	3	9	MEDIUM	164.310(a)(1); 164.310(c)

L = Likelihood (1–5) | I = Impact (1–5) | Score = L × I | CRITICAL: 20–25 | HIGH: 15–19 | MEDIUM: 8–14 | LOW: 1–7

Critical Risk Narratives

R-01: Ransomware via Spear-Phishing (Score: 25 — CRITICAL)

Ransomware delivered through targeted phishing email represents the highest-priority risk to SunRidge Health Partners. Healthcare organizations are the #1 target for ransomware globally, accounting for 17% of all ransomware events. The

attack vector in the Ascension Health breach (May 2024) was identical to SunRidge's current exposure profile: a phishing email targeting clinical or administrative staff with no advanced email threat protection, no phishing simulation program, and annual-only security awareness training.

A successful ransomware attack on SunRidge would likely encrypt Epic EHR across all four facilities, disable clinical operations, trigger mandatory breach notification for up to 85,000 patients, and require weeks of paper-based operations. At 287 inpatient beds with a Medicare-heavy census, clinical disruption of this scale poses direct patient safety risk. Immediate investments in advanced email threat protection, network segmentation, and phishing simulation are the highest-priority remediation actions in this SRA.

R-02: Third-Party Clearinghouse Compromise (Score: 20 — CRITICAL)

SunRidge's billing operations are entirely dependent on a single third-party clearinghouse Business Associate. The Change Healthcare ransomware attack (February 2024) demonstrated precisely what happens when this single point of failure is exploited: SunRidge experienced 11 days of billing disruption, representing significant revenue impact. The current Business Associate Agreement has not been reviewed or updated since 2021 and does not require MFA, encryption, 24-hour breach notification, or any minimum cybersecurity standards from the BA.

More critically, if the clearinghouse were to experience a breach similar to Change Healthcare, SunRidge's claims data — covering diagnoses, treatment histories, Social Security numbers, and insurance information for the entire 85,000-patient active population — could be exposed. As a covered entity, SunRidge bears shared enforcement liability for BA breaches when reasonable oversight was not exercised.

R-09: Web Tracking Pixel PHI Disclosure (Score: 15 — HIGH / Active Violation)

This risk represents an active, ongoing HIPAA Privacy Rule violation that was discovered during SRA preparation and requires immediate remediation independent of risk score. Google Analytics and Meta Pixel tracking codes are currently embedded on SunRidge's patient appointment scheduling pages. These technologies transmit user session data — including the conditions or services searched, provider selections, and appointment types — to third-party advertising platforms without patient authorization.

Per HHS OCR's December 2022 bulletin on the use of online tracking technologies, any disclosure of PHI through tracking technologies to third parties who are not Business Associates constitutes an impermissible disclosure under 45 CFR 164.502(a). Kaiser Permanente's 2024 disclosure (13.4M patients) and subsequent OCR investigations have confirmed this is an active enforcement priority. Civil monetary penalties have been imposed in multiple similar cases. SunRidge's compliance team must immediately remove all tracking pixels and assess the scope of disclosure for potential breach notification determination.

HIPAA SECURITY RULE — CONTROL GAP SUMMARY

This assessment evaluated 30 HIPAA Security Rule standards and implementation specifications across Administrative, Physical, and Technical Safeguard categories. The following table provides a high-level summary. Detailed findings are in the accompanying Excel workbook (Tab: Control Gap Assessment).

COMPLIANT	1 control (3%) — Workstation Use Policy (164.310(b)) — policy documented and distributed.
PARTIAL	14 controls (47%) — Controls exist but with identified gaps in enforcement, scope, or documentation.
GAP	14 controls (47%) — No adequate control currently in place. Highest concentration in Access Control and Contingency Planning.
IN PROGRESS	1 control (3%) — Risk Analysis (164.308(a)(1)) — this SRA constitutes the risk analysis in progress.
Critical Gap Areas	Encryption at rest/in transit (164.312(a)(2)(iv), 164.312(e)(2)(ii)) MFA / Authentication (164.312(d)) Disaster Recovery Plan (164.308(a)(7)) Account De-provisioning (164.308(a)(3)) Audit Log Review (164.308(a)(1)(ii)(D))
NPRM Impact	13 of 14 identified GAPs would become explicitly required (non-addressable) under the proposed HIPAA Security Rule Final Rule.
Overall Posture	PARTIAL — Significant regulatory exposure. Organization must prioritize MFA, encryption, and continuity planning.

RECOMMENDATIONS AND REMEDIATION ROADMAP

The following phased remediation roadmap addresses all identified risks in priority sequence. Total estimated investment is approximately \$303,500 over 365 days, with annual recurring costs of ~\$120,000 thereafter for ongoing programs. This investment must be weighed against OCR civil monetary penalty exposure of up to \$1.9 million per violation category per year — and the operational and reputational cost of a breach affecting SunRidge's 85,000 patients.

Phase 1: Immediate Actions (0–30 Days)

Total Phase 1 Investment: ~\$36,000

- ◆ IMMEDIATE (Day 1–7): Remove all web tracking pixels (Google Analytics, Meta Pixel) from all patient-facing scheduling and portal pages. Engage legal counsel for breach notification scope assessment. Cost: \$0 remediation / \$20,000+ legal.
- ◆ IMMEDIATE (Day 1–14): Isolate the LabCore HL7 legacy server (Windows Server 2012 R2, EOL) on a dedicated VLAN with strict ACL rules. Document as compensating control per 164.306(d). Cost: \$3,000.
- ◆ IMMEDIATE (Day 1–30): Enable multi-factor authentication on all remote Epic EHR access. Prioritize all provider and administrative accounts. Cost: \$8,000.
- ◆ IMMEDIATE (Day 1–30): Conduct emergency security review of the billing clearinghouse Business Associate. Verify BAA currency. Identify alternate clearinghouse for business continuity. Cost: \$5,000.
- ◆ (Day 1–14): Reduce workstation auto-lock to 5 minutes across all clinical systems via Group Policy. Cost: \$0.

Phase 2: Short-Term Actions (31–90 Days)

Total Phase 2 Investment: ~\$84,000

- ◆ Deploy advanced email threat protection with DMARC/DKIM enforcement and sandboxing. Launch first phishing simulation exercise for all staff. Cost: \$18,000.
- ◆ Conduct telehealth platform security configuration audit. Enforce waiting rooms, unique meeting IDs, and session encryption for all Teladoc appointments. Update BAA with Teladoc. Cost: \$6,000.
- ◆ Implement same-day account de-provisioning. Automate Active Directory account disable trigger from HR system upon termination. Cost: \$6,000.
- ◆ Update all 14 Business Associate Agreements with new template requiring MFA, encryption, and 24-hour breach notification. Engage legal counsel. Cost: \$10,000.
- ◆ Initiate LabCore migration planning — engage vendor for extended support options or begin Epic Lab module implementation scoping. Cost: \$45,000.
- ◆ Implement automated account de-provisioning workflow tied to HR termination process. Cost: \$6,000.

Phase 3: Mid-Term Actions (91–180 Days)

Total Phase 3 Investment: ~\$86,000

- ◆ Deploy Mobile Device Management (MDM) solution for all issued and BYOD devices. Enforce full-disk encryption and remote-wipe capability. Cost: \$25,000/yr.
- ◆ Establish formal Third-Party Risk Management (TPRM) program with BA risk tiering and annual security questionnaires for Tier 1 BAs. Cost: \$15,000.

- ◆ Enable multi-factor authentication on MyChart patient portal. Phase 1: optional. Phase 2: mandatory within 60 days. Cost: \$8,000.
- ◆ Develop and test Business Continuity Plan and Disaster Recovery Plan with defined RTO/RPO for all critical systems. Conduct tabletop exercise. Cost: \$20,000.
- ◆ Implement access recertification cycle (90-day) and privileged access management for IT administrative accounts. Cost: \$18,000.

Phase 4: Strategic Investments (181–365 Days)

Total Phase 4 Investment: ~\$95,000

- ◆ Conduct external penetration test (network + web application + social engineering). Remediate all critical and high findings within 60 days. Cost: \$35,000.
- ◆ Implement network segmentation isolating clinical VLAN, administrative VLAN, and guest networks. Deploy next-generation firewall with deep packet inspection. Cost: \$50,000.
- ◆ Deploy SIEM solution for centralized log aggregation across Epic, Active Directory, LabCore, and network infrastructure. Establish alert monitoring. Cost: \$42,000/yr.
- ◆ Achieve alignment with NIST CSF 2.0 and HIPAA Security Rule NPRM proposed requirements in advance of Final Rule compliance date. Cost: \$25,000.
- ◆ Conduct annual HIPAA Security Rule compliance evaluation per 164.308(a)(8). Engage external assessor every two years. Cost: \$18,000.

CONCLUSION

SunRidge Health Partners faces a healthcare threat environment that has never been more hostile. The 2024–2025 period has demonstrated that ransomware, supply chain attacks, and unauthorized data disclosure are not theoretical risks — they are operational realities affecting organizations of comparable size and complexity, including those in Florida's healthcare sector.

This Security Risk Analysis establishes the factual foundation for SunRidge's risk management program as required under 45 CFR 164.308(a)(1). The findings are clear: the organization's current security posture requires significant investment to protect the confidentiality, integrity, and availability of ePHI for 85,000 patients who depend on SunRidge for their care — and to ensure compliance with both current HIPAA requirements and the forthcoming Security Rule Final Rule.

The highest-priority actions — removing unauthorized tracking pixels, isolating the end-of-life lab interface system, enabling multi-factor authentication on remote EHR access, and engaging the billing clearinghouse on BAA and business continuity — can each be completed within 30 days at relatively low cost. These actions alone materially reduce SunRidge's regulatory exposure and operational risk.

The organization's leadership should treat this SRA not as a compliance exercise, but as the first deliverable in an ongoing risk management program. This document must be reviewed and updated annually — or whenever a significant operational or environmental change occurs — per 164.308(a)(8) and the proposed NPRM annual audit requirement.

This SRA was prepared using the NIST SP 800-30 Rev. 1 methodology and HHS SRA Tool guidance. The accompanying Excel workbook (SunRidge_HIPAA_SRA_2025.xlsx) contains the complete ePHI inventory, threat library, risk register with full risk narratives, HIPAA control gap assessment for 30 controls, and phased remediation roadmap with cost estimates and ownership assignments. Both documents together constitute SunRidge's 2025 HIPAA Security Risk Analysis.